

HiveForce Labs

THREAT ADVISORY



ATTACK REPORT

Microsoft SmartScreen Flaw Used for Covert Stealer Deliveries

Date of Publication

July 9, 2024

Admiralty Code

A1

TA Number

TA2024265

Summary

Attack Discovered: July 2024

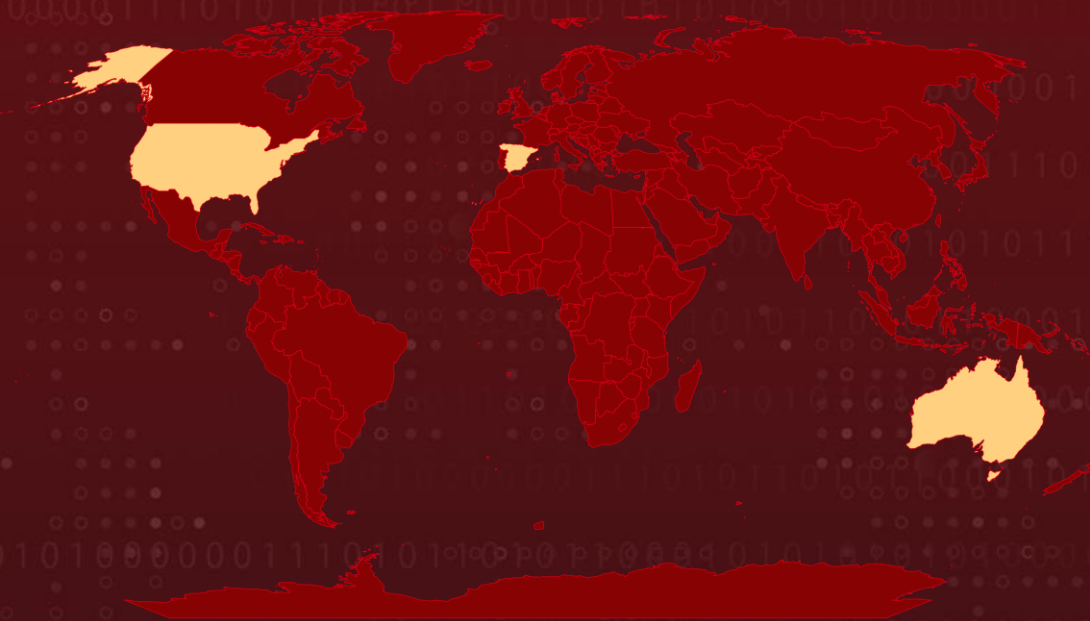
Attack Region: Spain, US, and Australia

Targeted Industries: Spanish taxpayers, transportation companies

Malware: Lumma and Meduza Stealer

Attack: An active campaign exploiting the Microsoft SmartScreen vulnerability CVE-2024-21412 has been discovered. Threat actors have leveraged this vulnerability to bypass Microsoft Defender SmartScreen and deploy payloads on victims’ systems. The attack employs a multifaceted approach, utilizing various script files, including PowerShell and JavaScript, to deliver the final payload. This multi-stage process ultimately culminates in the deployment of malicious payloads like Lumma and Meduza Stealer, both of which focus on collecting sensitive information from the victim’s machine.

🔪 Attack Regions



Powered by Bing
© Australian Bureau of Statistics, GeoNames, Microsoft, Navinfo, Open Places, OpenStreetMap, TomTom, Zenrin

⚙️ CVE

CVE	NAME	AFFECTED PRODUCT	ZERO -DAY	CISA KEV	PATCH
CVE-2024-21412	Microsoft Windows Internet Shortcut Files Security Feature Bypass Vulnerability	Microsoft Windows Internet Shortcut Files	✔️	✔️	✔️

Attack Details

#1

An active cyber attack recently targeted Spanish taxpayers, transportation companies, and Australian citizens by disguising malicious links as Medicare enrollment forms in spam emails. Clicking these links redirected victims to a WebDAV share hosting an internet shortcut file. Exploiting [CVE-2024-21412](#) allowed the attackers to bypass Microsoft Defender SmartScreen and execute an LNK file also located on the share, effectively compromising user systems.

#2

The attackers utilized script files such as PowerShell and JavaScript in a multi-stage process to deliver a final payload of malicious software, including Lumma and Meduza Stealer, designed specifically to steal sensitive information from victims' computers.

#3

Execution of the LNK file involved using the legitimate Windows utility 'forfiles' to locate the 'win.ini' file in the C:\Windows directory and running a PowerShell command. PowerShell leverages 'mshta.exe' to launch a remote file containing embedded malicious JavaScript. This technique leveraged MSHTA's capability to execute embedded scripts like VBScript or JavaScript within various file types, complicating detection efforts.

#4

This JavaScript downloaded a decoy document and an installer from a remote server, saving them to a hidden directory. Subsequently, it opened the decoy document and initiated the installer, dropping multiple files including legitimate files, dependency DLLs, a malicious DLL for side-loading, and an encrypted loader.

#5

Once all necessary files were in place, the installer utilized DLL side-loading by executing a legitimate file, loading the malicious DLL. This DLL decrypted the loader's content and injected the payload into explorer.exe. The payload, comprising Lumma and Meduza Stealer, then initiates the data theft process and compromises the system.

#6

In an earlier campaign, the [Water Hydra](#) APT group leveraged CVE-2024-21412 in a targeted attack to bypass SmartScreen and deploy the DarkMe RAT. These campaigns underscore the evolving threat landscape, where cybercriminals exploit vulnerabilities such as CVE-2024-21412 alongside sophisticated techniques like DLL side-loading and IDATLoader. Effective countermeasures require continuous adaptation and proactive security measures to safeguard digital environments.

Recommendations



Exercise Caution with Unsolicited Emails: Always exercise caution when receiving unexpected or urgent emails, especially those from unknown sources. Avoid downloading attachments from unsolicited emails to mitigate the risk of malware infections.



Verify the Source: Only download and open files from sources you trust. If you receive a file via email, chat, or any other communication platform, confirm its legitimacy with the sender before opening it.



Implement Proactive PowerShell Security Measures: Configure PowerShell execution policies to limit script execution solely to those that are signed or originate from trusted locations. Additionally, enhance security by creating a firewall rule to block outbound traffic for PowerShell and using Endpoint Application Control to whitelist approved applications and scripts.



Network Segmentation: Implement network segmentation to restrict the lateral movement of attackers within the network. Segment critical systems and sensitive data from less secure areas of the network to minimize the impact of a successful breach.



Patch Management: Maintain a rigorous patch management process to ensure that all software, including operating systems, web browsers, and security applications, is up-to-date with the latest security patches. Promptly apply patches released by software vendors to mitigate known vulnerabilities.



Potential MITRE ATT&CK TTPs

<u>TA0042</u> Resource Development	<u>TA0001</u> Initial Access	<u>TA0002</u> Execution	<u>TA0004</u> Privilege Escalation
<u>TA0005</u> Defense Evasion	<u>TA0011</u> Command and Control	<u>T1588</u> Obtain Capabilities	<u>T1588.006</u> Vulnerabilities
<u>T1566</u> Phishing	<u>T1566.002</u> Spearphishing Link	<u>T1190</u> Exploit Public-Facing Application	<u>T1059</u> Command and Scripting Interpreter
<u>T1059.001</u> PowerShell	<u>T1059.007</u> JavaScript	<u>T1218</u> System Binary Proxy Execution	<u>T1218.005</u> Mshta

<u>T1036</u> Masquerading	<u>T1027</u> Obfuscated Files or Information	<u>T1574</u> Hijack Execution Flow	<u>T1574.002</u> DLL Side-Loading
<u>T1055</u> Process Injection	<u>T1071</u> Application Layer Protocol	<u>T1204</u> User Execution	<u>T1204.001</u> Malicious Link

✂ Indicators of Compromise (IOCs)

TYPE	VALUE
SHA256	58e2b766dec37cc5fcfb63bc16d69627cd87e7e46f0b9f48899889479f12611e, 268a0de2468726a106fd92563a846e764f2ba313e37b5fc0cf76171b0a363f6f, aceee450c55d61671c2d3d154b5f77e7f99688b6da8a8f3256a4bae2c db76a4c, 2460e7590e09af09ced6f75c001a9066c18629d956edbe8041f08cd21b7528b2, 4eccb7813cee8c8039424aebf69f4269d4a6c2c72d81a001254bcdce80034555, 6481462f15ad4213f83a3d28304f14496bae1feb8580056959a657d0ee8981db, 7ee31fa89e9e68f20004bdc31f8f05a95861b6c678bfa3b57f09dfad9ef5290, 81e89754ae2324c684fce71acafc30f8085870be947e7a76971b4fec1b24b5d1, 473abb2c272295473e5556ec7dec06f2018c0a67f208d8ab33de1fb6d40895f5

✂ Patch Link

<https://msrc.microsoft.com/update-guide/vulnerability/CVE-2024-21412>

✂ References

<https://cyble.com/blog/increase-in-the-exploitation-of-microsoft-smartscreen-vulnerability-cve-2024-21412/>

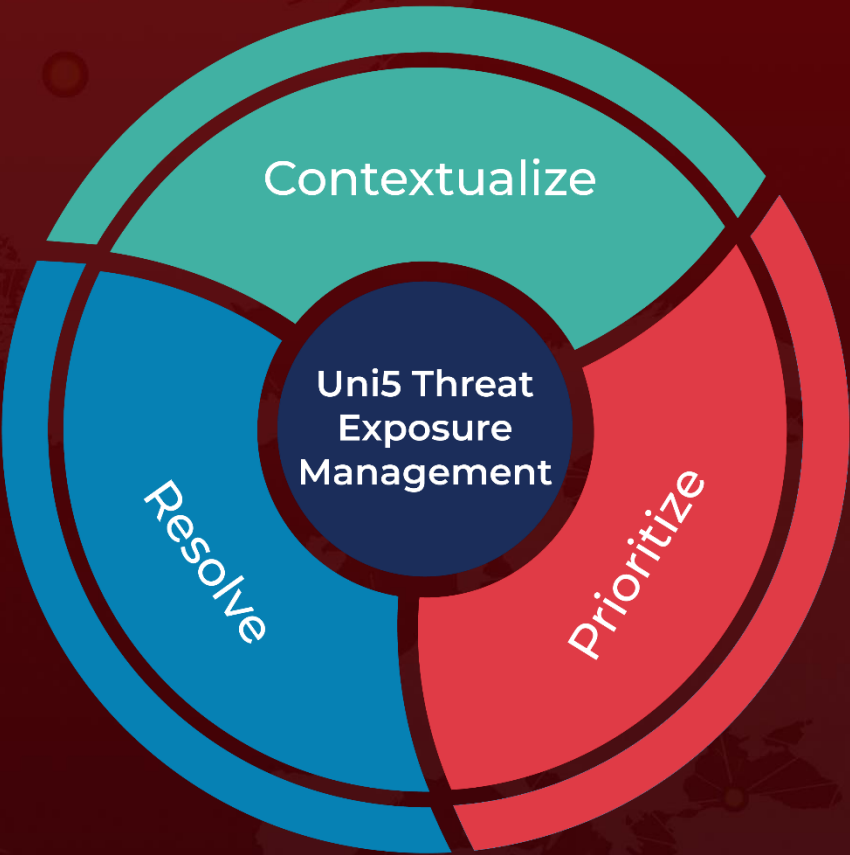
<https://www.hivepro.com/threat-advisory/microsofts-february-2024-patch-tuesday-addresses-two-zero-day-vulnerabilities/>

<https://www.hivepro.com/threat-advisory/water-hydra-exploits-cve-2024-21412-to-target-financial-traders/>

What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with HivePro Uni5: Threat Exposure Management Platform.



REPORT GENERATED ON
July 9, 2024 • 7:00 AM

